

# 보안 · 기밀 · 테년시 ● 쉽게 읽기

"누구의 자료가 새지 않고, 누가 무엇을 근거로 답했는지"를 끝까지 통제·추적

docs / 01\_보안\_기밀\_테년시.md → 비개발자(KICPA)용 도식 해설



고객별 격리 · 누수 = 0



직함이 아니라 배정(RoleAssignment)



변조방지 감사로그 · 재현성

작성 · 신현우 (KICPA, 2년차)

목적 · 딜로이트 안진 Business Tax 지원 / 포트폴리오

문서 · 법인세 자문 보조 AI 설계서 — 보안 章 해설본

범위 · SEC-001 ~ SEC-017

## 30초 요약 — 이 문서(01)가 뭐죠?

한 문장: 고객 세무자료를 다루는 AI에서 모델 성능보다 먼저 갖춰야 하는 고객별 격리 · 최소권한 · 반출통제 · 감사추적의 규칙을 모은 문서입니다. = AI판 독립성·기밀유지 통제.

### ① 격리

A고객 자료가 B고객 답변에 절대 안 섞이게. 누수 테스트 0건이 합격선.

### ② 최소권한

"CPA 직함"만으론 못 봄. 해당 건(Matter)에 지정돼야 접근.

### ③ 추적

누가 언제 무엇을 조회·반출했는지 관리자도 못 지우는 로그.

## 회계사의 직관으로 — 3가지 비유

### 비유 1 · 감사 조서철과 「고객별 캐비닛」

A고객 감사조서가 B고객 파일철에 섞이면 독립성·기밀 중대사고죠. 그래서 모든 자료에 **client\_id**를 박고, 고객별 인덱스를 나누고, 검색 시 테넌트 필터를 강제합니다. 부가기능이 아니라 기본통제. SEC-001/002/003

### 비유 2 · 「권한 매트릭스」와 담당 배정

감사팀원이 "회계사"라고 모든 고객 조서를 볼 순 없고 해당 engagement에 지정돼야 하죠. 권한은 전역 직함이 아니라 사용자 × 역할 × 건(Matter) = RoleAssignment로 판단합니다. SEC-006/012

### 비유 3 · 「감사추적표」와 WORM 보관

누가 언제 무엇을 조회·수정·반출했는지 남기고, 관리자조차 사후 삭제 못 해야 증거가 됩니다. = append-only 변조방지 로그 + legal hold. SEC-007/017

### ⚠ 가장 무거운 한 줄

전직장(前 직장) 고객자료는 익명화해도 반입·임베딩 자체가 금지입니다(비밀유지·직업윤리). 합법 소싱(공개 법령·라이선스 실무서·합성 예시)만 사용. SEC-004

## 도식 ① — 위협 → 통제 → 요구사항(FR) 매핑

"무엇이 잘못될 수 있나"를 먼저 적고, 각 위협을 어떤 통제로 막는지 1:1로 연결했습니다. = 감사의 위협평가 → 통제활동.

| 위협 (무엇이 터지나)              | 1차 통제 (어떻게 막나)                                 | 근거 FR           |
|---------------------------|------------------------------------------------|-----------------|
| T1 테넌트 누수<br>A고객 자료가 B답변에 | client_id 격리 · 검색단계 테넌트 필터 강제 · 고객별 인덱스 분리     | SEC-001/002/003 |
| T2 전직장 자료 반입              | 업로드 confidentiality·라이선스 분류 · 무권한 자료 반입·임베딩 차단 | SEC-004         |
| T3 외부 API로 유출             | 기밀등급별 전송정책 · zero-retention 계약 · 마스킹 · DLP     | SEC-005/008/014 |
| T4 과다권한<br>봐선 안 될 자료 열람   | 기본 deny · RoleAssignment · 문서 ACL · 최소권한       | SEC-006/012     |
| T5 로그 변조                  | append-only 변조방지(WORM) 감사로그 · 관리자도 삭제 불가       | SEC-017         |
| T6 관리자 남용                 | 고객 원문 직접열람 금지 · break-glass 승인·기록·사후검토         | SEC-011         |
| T7 삭제 누락<br>지웠는데 파편 남음    | 문서→chunk→embedding→cache→파생까지 연쇄삭제·비식별         | SEC-009/016     |
| T8 재현 불가<br>왜 그 답이 나왔나    | 답변→검색·근거·모델·프롬프트·법령버전 추적 보존                    | SEC-007         |

### 💡 회계사 포인트

통제를 나열만 한 게 아니라 **위협마다 1차 방어를 지정**했습니다. 파트너가 "이건 어떻게 막죠?"라 물으면 표의 한 줄로 답합니다 — 감사 통제기술서와 같은 구조.

## 도식 ② — 테넌시 격리 구조 (고객 칸막이)

테넌시 = 고객/조직별 데이터 칸막이. 모든 데이터에 소속 고객키가 박혀, 경계를 넘는 접근이 원천 차단됩니다.



### 모든 데이터 객체에 `client_id`가 박힌다



→ `client_id` 없는 데이터 = 격리 실패로 간주. 검색·생성·로그 어디서도 칸막이가 유지됩니다.

### 공용 vs 고객 인덱스

공용(L0~L2): 법령·예규·라이선스 실무서 — 모두 공유.

고객(L3~L4): 원장·계약·검토메모 — 고객별 분리 저장, 교차검색 금지.

### ⚠ 불변

검색 단계에서 테넌트 필터를 끌 수 없습니다(필터 누락 가능한 구조 자체 금지). 교차 누수 0건이 합격선. SEC-002

## 도식 ③ — 권한 판단 흐름 ("직함"이 아니라 "배정")

접근 요청이 오면 기본은 거부(deny). 아래 관문을 모두 통과해야 열립니다. = 조서 접근권한 평가.

기본  
DENY

아무 것도 기본 허용 안 함  
명시적으로 부여된 것만 접근 가능

출발점

1

**RoleAssignment 확인** — 이 사용자가 이 역할로 배정됐나  
사용자 × 역할 × 범위(Matter/Engagement)

SEC-012

2

**Matter 배정 확인** — 그 건(고객/사건)에 실제 배정됐나  
CPA여도 미배정 건은 ×

SEC-006

3

**문서 ACL 확인** — 그 문서를 볼 권한이 있나  
문서 단위 접근목록

문서 ACL

4

**L4 민감자료 별도 grant** — 최고등급은 추가 승인  
기본 배정만으론 부족

별도 승인

### 💡 핵심

"이 사람 회계사니까 다 봐도 됨" × → "이 건에 배정됐고, 이 문서 ACL이 있고, L4면 별도 승인까지" ✓. 최소권한 (least privilege)의 전산화입니다.

## 도식 ④ — 데이터 등급(L0~L4)별 외부전송 정책

자료를 민감도로 등급화하고, 등급별로 "외부 AI/API에 보내도 되는지"를 못박았습니다. = 정보등급 분류·반출통제.

| 등급       | 예시             | 외부 API 전송  | 필수 통제                  |
|----------|----------------|------------|------------------------|
| L0 공개    | 공포 법령·국세청 공개자료 | ✔ 가능       | 출처·시점 기록               |
| L1 라이선스  | 제휴 실무서·서적      | ✔ 가능(약관 내) | SourceLicense 확인       |
| L2 합성/일반 | 합성 예시·일반 플레이북  | ⚠ 조건부      | 식별정보 없음 확인             |
| L3 고객 업무 | 원장·계약·검토메모     | ⚠ 마스킹 필요   | 마스킹·zero-retention·DLP |
| L4 최고 민감 | 주민번호·핵심영업비밀    | ❌ 원칙 금지    | 프라이빗 배포·별도 grant       |

### 반출 3대 통제

- **zero-retention**: 외부 제공자가 전송분 학습·보관 안 함(계약)
- **마스킹**: 식별정보 가린 뒤 전송
- **DLP**: 출력·다운로드·외부호출로 새는지 탐지·차단

### ❌ 금지

"외부 API가 편하니 고객자료도 그냥 보내자" X. 등급이 전송 가능여부를 결정합니다. L4는 원칙적으로 외부에 나가지 않습니다. SEC-005/008/014

## 도식 ⑤ — 데이터 생명주기 (들어와서 지워질 때까지)

자료가 수집부터 삭제까지 거치는 길과, 지울 때 파편까지 연쇄삭제되는 범위를 정의했습니다.

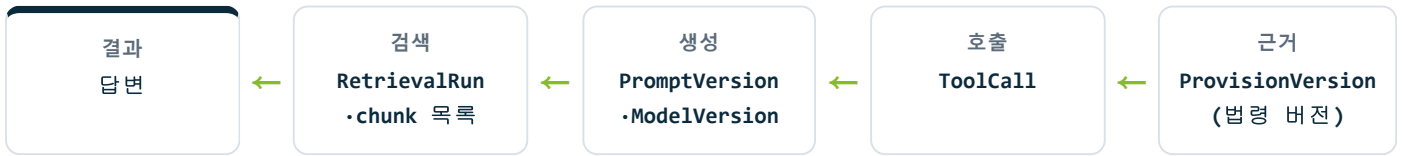


### ⊘ "문서만 지우면 끝" 이 아니다

원본 문서를 지워도 **chunk·임베딩 벡터·캐시·파생 데이터**가 남으면 누수입니다. 삭제 요청 시 **모든 파편을 연쇄삭제**하거나 **비식별화**해야 합니다. SEC-009/016

## 도식 ⑥ — 감사로그 · 재현성 (왜 그 답이 나왔나)

답변 하나를 그 근거·모델·시점까지 통째로 복원할 수 있어야 합니다. = 조서 cross-reference.



→ 임의의 답변을 골라 "어떤 자료를·어느 법령버전으로·어떤 모델·프롬프트로" 만들었는지 100% 재현. SEC-007

## 도식 ⑦ — 관리자 break-glass (비상 열람 통제)

관리자(Admin)도 고객 원문을 마음대로 못 봅니다. 비상시엔 유리를 깨는 별도 절차로만.

평시

**Admin도 고객 원문 직접열람 X**  
운영 권한 ≠ 내용 열람 권한

기본 차단

비상

**break-glass — 사유 입력 → 승인 → 한시 열람**  
모든 행위 기록·사후검토 대상

승인 필요

사후검토

💡 Big4 포인트

운영 권한과 내용 열람 권한을 분리한 것. "관리자니까 다 본다"는 Big4 고객 데이터 통제에서 통하지 않습니다.  
SEC-011/017



# 비개발자를 위한 전문용어 사전

이 문서에 자주 나오는 보안 용어를 회계사 눈높이로 풀었습니다.

|                                    |                                                             |
|------------------------------------|-------------------------------------------------------------|
| <b>테넌시</b><br>Tenancy              | 고객/조직별 데이터 칸막이. 한 시스템을 쓰더라도 고객 자료는 논리·물리적으로 분리.             |
| <b>client_id</b><br>격리 키           | 모든 고객 데이터에 붙는 <b>고객 식별자</b> . 없으면 격리 실패로 간주하는 핵심 키.         |
| <b>RBAC</b><br>Role-Based Access   | <b>역할 기반 접근통제</b> . 단, 여기선 직함만이 아니라 <b>배정 범위</b> 와 함께 판단.   |
| <b>ACL</b><br>Access Control List  | <b>문서 단위 접근목록</b> . 특정 사용자·역할이 그 문서를 볼 수 있는지 정함.            |
| <b>RoleAssignment</b><br>권한 배정 기록  | <b>사용자 × 역할 × 건(Matter/Engagement)</b> 을 묶어 실제 권한을 부여하는 기록. |
| <b>위협모델</b><br>Threat Model        | 어떤 사고가 날 수 있고 무엇으로 막을지 정리한 <b>위험 지도</b> . = 감사 위험평가.        |
| <b>DLP</b><br>Data Loss Prevention | 민감정보가 <b>출력·외부 API·다운로드</b> 로 새는지 탐지·차단하는 통제.               |
| <b>Zero-retention</b><br>무보관       | 외부 AI/API 제공자가 <b>전송 데이터를 학습·보관하지 않도록</b> 한 계약 조건.          |
| <b>Break-glass</b><br>비상 열람        | 예외 상황에서 관리자 접근을 <b>별도 승인+감사로그</b> 로만 허용하는 절차.               |
| <b>WORM 로그</b><br>append-only      | 한 번 기록하면 <b>관리자도 임의 삭제·수정 못 하는</b> 변조방지 감사로그.               |
| <b>Legal hold</b><br>보존 의무         | 분쟁·조사 대비로 <b>특정 자료의 삭제를 일시 중단</b> 해 보존하는 조치.                |
| <b>최소권한</b><br>Least Privilege     | 업무에 <b>꼭 필요한 만큼만</b> 권한 부여. 기본은 거부(deny).                   |

# 흔한 오해 8 — "이렇게 말하면 틀립니다"

보안을 소개할 때 자주 빠지는 함정입니다. 오른쪽이 정확한 설명입니다.

| # | ❌ 이렇게 말하면 틀림              | ✅ 정확히는                            | 근거          |
|---|---------------------------|-----------------------------------|-------------|
| 1 | "Role이 CPA면 고객자료를 본다"     | 해당 Matter에 RoleAssignment가 있어야 함  | SEC-006/012 |
| 2 | "검색할 때 필터만 잘 넣으면 됨"       | retrieval API에서 테넌트 필터를 끌 수 없게 강제 | SEC-002     |
| 3 | "고객자료·공용 법령 같은 DB에 뒤도 OK" | L3/L4 고객 인덱스와 공용 인덱스 분리           | SEC-003     |
| 4 | "익명화하면 전직장 자료 넣어도 됨"      | 반입·임베딩 자체 금지 · SourceLicense 필요   | SEC-004     |
| 5 | "Admin이면 원문을 본다"          | 고객 원문은 break-glass 승인·기록 대상       | SEC-011     |
| 6 | "외부 API 편하면 고객자료도 전송"     | 등급별 전송정책·zero-retention·마스킹 강제    | SEC-005/014 |
| 7 | "문서만 삭제하면 끝"              | chunk-embedding-cache·파생까지 연쇄삭제   | SEC-009     |
| 8 | "로그는 DB에 남기면 충분"          | 관리자도 못 지우는 변조방지 로그                | SEC-017     |

### 한 문장 소개

"감사에서 배운 조서보안·접근권한을 AI에 옮겨, 고객 데이터가 섞이지 않고 누가 무엇을 근거로 답했는지 끝까지 추적되게 만들었습니다."

### 왜 중요

Big4·세무 고객은 성능보다 데이터 통제를 먼저 봅니다. 감사 배경 회계사가 보안을 정확히 아는 것이 강점.

## 이 문서를 왜 이렇게 썼나 — 핵심 메시지 3

### 01 성능보다 먼저, 격리·최소권한·반출통제

고객 세무정보 AI의 1순위는 모델 성능이 아니라 **고객별 격리·최소권한·반출통제**입니다. 누수 테스트 0건이 합격선.

### 02 권한은 "직함"이 아니라 "배정 + 문서 ACL"

RoleAssignment + Matter 범위 + 문서 ACL로 판단합니다. CPA여도 미배정 건은 못 봅니다 — **최소권한**의 전산화.

### 03 답변은 근거·모델·시점까지 재현 가능해야

생성 결과만 남기면 부족합니다. **검색·근거·모델·프롬프트·감사로그**까지 변조 없이 보존돼야 "왜 그 답인지" 복원됩니다.

#### 면접 한 줄

"저는 감사에서 배운 **조서보안·접근권한 사고방식**을 AI 설계에 옮겨, 고객 데이터가 섞이지 않고 누가 무엇을 근거로 답했는지 끝까지 추적되는 구조를 만들었습니다."

Tax Intelligence Workspace (TIW) · 법인세 자문 보조 AI 설계서  
본 해설본은 docs/01\_보안\_기밀\_테넌시.md의 비개발자용 도식 요약입니다 · 정본은 원문을 따릅니다